

PLANTILLA POWERPOINT: REPORTE RESULTADOS ENCUESTA DORA

Presentación Ejecutiva de Hallazgos (12 Slides)

Versión: 1.0

Fecha: Enero 2026

Clasificación: Profesional — Presentación para Junta Directiva

Duración: 20-30 minutos + Q&A

ESTRUCTURA: 12 SLIDES

SLIDE 1: Portada

Contenido:

ENCUESTA DE CIBERSEGURIDAD DORA 2026	
RESULTADOS EJECUTIVOS	
Estado de Madurez Ciberseguridad	
[Logo Institución]	[DORA Logo]
Enero 20, 2026	
Presentado a: Junta Directiva	
Respondentes: 12 personas clave	

Elementos: Logo institución + DORA; fecha; audiencia; fondo profesional

SLIDE 2: Agenda y Contexto

Contenido:

AGENDA DE LA PRESENTACIÓN:

1. **CONTEXTO:** ¿Por qué esta encuesta?
↓ DORA compliance obligatorio 2025+; auditoría Q2-Q3 2026
2. **METODOLOGÍA:** ¿Cómo evaluamos?
↓ 128 preguntas × 8 módulos; escala 1-5 madurez; CMI ponderado
3. **RESULTADOS:** ¿Dónde estamos?
↓ CMI actual 2.8/5.0 (MANAGED); distributed por pilar
4. **GAPS:** ¿Qué nos falta?
↓ Prioridades inmediatas y críticas identificadas
5. **ROADMAP:** ¿Cómo mejoramos?
↓ Fases 1-3; presupuesto; timelines; responsables
6. **FINANCIERO:** ¿Cuál es el ROI?
↓ €730K inversión; €1M+ ALE reduction; 242% ROSI
7. **RECOMENDACIONES:** ¿Qué decide la Junta?
↓ 3 mociones para aprobación inmediata

SLIDE 3: Contexto Regulatorio DORA

Contenido:

¿QUÉ ES DORA?

Digital Operational Resilience Act (Reglamento EU 2022/2554)

OBJETIVO: Fortalecer resiliencia ciberseguridad sector financiero EU

APLICACIÓN: España

- Bancos (todos tamaños)
- Aseguradoras
- Asset Managers (SGIIC/SGEIC)
- Proveedores servicios críticos

DEADLINE:

- ✓ Enero 2025: Aplicable (Ya en vigor)
- ✓ Próximo: Supervisory audits Q2-Q3 2026

REQUISITOS CLAVE:

- ICT Risk Management Framework (Art. 6-10)
- Incident Detection <15 minutos (Art. 18)
- Third-party Risk Management (Art. 28-30)
- Threat-Led Penetration Testing bienal (Art. 26)
- Resilience Testing anual (Art. 25)

SLIDE 4: Metodología Encuesta

Contenido:

CÓMO EVALUAMOS:

Preguntas: 128 preguntas específicas DORA
Módulos: 8 módulos (Gobernanza, Riesgos, Incidentes, etc.)
Escala: 1-5 (Ad-hoc → Optimized)
Respondentes: 12 personas clave (CISO, CRO, Compliance, etc.)
Cobertura: 100% Artículos DORA (5-30)

ESCALA DE MADUREZ:

- 1 (Ad-hoc): No existe; muy básico; procesos manuales
- 2 (Developing): Existe pero incompleto; gaps significativos
- 3 (Managed): Conforme DORA; con gaps menores
- 4 (Integrated): Totalmente alineado DORA; best practices
- 5 (Optimized): Excelencia; continuous improvement

CMI (Cybersecurity Maturity Index):

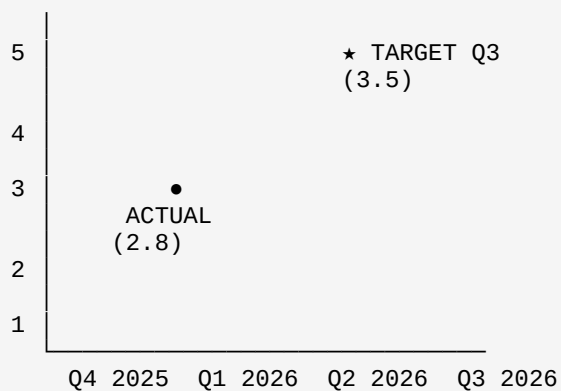
Ponderación:

- Gobernanza (25%)
- Riesgos (20%)
- Incidentes (20%)
- Vulnerabilidades (10%)
- SIEM (10%)
- Información/Acceso (10%)
- Capacitación (3%)
- Resiliencia (2%)

SLIDE 5: CMI Dashboard - Estado Actual

Contenido:

CYBERSECURITY MATURITY INDEX: 2.8/5.0 (MANAGED - Developing)



INTERPRETACIÓN:

- Estado ACTUAL: 2.8 = "MANAGED-Developing"
- Significa: Conforme DORA con gaps; requiere remediación
- Tendencia: +0.2 desde Q4 (positivo)
- Target: 3.5 para auditoría Q3 2026 (achievable)

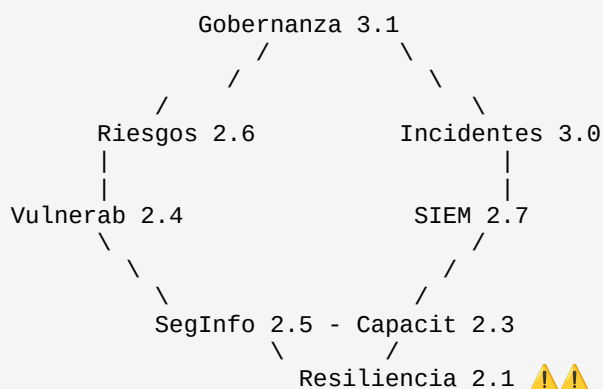
BENCHMARK:

- EU promedio: 2.7/5.0
- Mejor-en-clase: 4.2/5.0 (grandes bancos)
- Nuestra posición: Ligeramente arriba promedio

SLIDE 6: CMI por Módulo (Radar Chart)

Contenido:

DESGLOSE POR MÓDULO DE LOS 8 PILARES:



STATUS POR MÓDULO:

- ✓ Gobernanza (3.1): Acceptable; governance básica en place
- ⚠ Riesgos (2.6): Needs work; FAIR quantification missing
- ✓ Incidentes (3.0): Acceptable; incident response formalized
- ⚠ Vulnerab (2.4): Needs work; scanning + TLPT needs acceleration
- ⚠ SIEM (2.7): Needs work; MTTD currently 18min (target 15)
- ⚠ SegInfo (2.5): Needs work; encryption roadmap incomplete
- ⚠ Capacitación (2.3): Needs work; training program basic
- ⚠⚠ Resiliencia (2.1): CRITICAL; BC/DR testing needed

PRIORIDADES INMEDIATAS:

1. Resiliencia (2.1) → Testing scheduling
2. Capacitación (2.3) → Training acceleration
3. SegInfo (2.5) → Encryption rollout

SLIDE 7: Gaps Críticos Identificados

Contenido:

BRECHAS MÁS IMPORTANTES (Score <2.5):

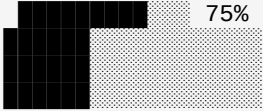
1. RESILIENCIA OPERATIVA (Módulo 8: Score 2.1)
  **CRÍTICO** - ART. 25 DORA
Gap: Business Continuity testing not completed
Impact: No RTO/RPO validation; BC plan not tested
Acción: Tabletop Q2; Site activation Q3; TLPT Q2
Costo: €80K
Target: 3.5/5.0 by Aug 2026
2. CAPACITACIÓN SEGURIDAD (Módulo 7: Score 2.3)
 **IMPORTANTE** - ART. 14 DORA
Gap: Training program existe pero limited scope
Impact: Staff awareness low; phishing click rate 12% (target <8%)
Acción: Expand curriculum; monthly phishing simulation
Costo: €50K
Target: 3.5/5.0 by Jun 2026
3. SEGURIDAD INFORMACIÓN (Módulo 6: Score 2.5)
 **IMPORTANTE** - ART. 9 DORA
Gap: Encryption coverage only 65% (target 100%)
Impact: Data at risk; legacy systems unencrypted
Acción: Encryption roadmap; prioritize critical data
Costo: €120K
Target: 3.8/5.0 by Aug 2026
4. RIESGOS TIC (Módulo 2: Score 2.6)
 **IMPORTANTE** - ART. 6 DORA
Gap: No formal FAIR quantification; ALE not calculated
Impact: Risk decisions without financial impact data
Acción: FAIR training Q2; implement ALE methodology
Costo: €40K
Target: 3.5/5.0 by May 2026

SLIDE 8: Roadmap de Remediación (Gantt)

Contenido:

ROADMAP FASES 1-3 (FEB 2026 - AGO 2026):

FASE 1 (Q1-Q2): CRÍTICOS

SIEM Deployment (MTTD <15min)	
FAIR Methodology Implementation	
Crisis Communication Validation	
Vendor Assessment Completion	
Presupuesto: €420K	
Target CMI: 3.0 → 3.2 (May 31)	

FASE 2 (Q2-Q3): RECOMENDADOS

Encryption Implementation	
BC/DR Testing (Tabletop + Site)	
TLPT Red Team Execution	
Phishing Simulation Program	
Presupuesto: €250K	
Target CMI: 3.2 → 3.5 (Jun 30)	

FASE 3 (Q3-Q4): DESEABLES

FAIR Quantification Completion	
GRC Platform Enhancement	
Board Dashboard Implementation	
Presupuesto: €80K	
Target CMI: 3.5 → 3.8 (Aug 31)	

TOTAL INVERSIÓN: €730K over 6 meses

TIMELINE: Feb 2026 - Aug 2026

READINESS para supervisory audit Q3 2026: PROBABLE APPROVAL

SLIDE 9: Análisis Financiero - ALE

Contenido:

ESTIMACIÓN DE IMPACTO ECONÓMICO (ANNUAL LOSS EXPECTANCY):

ESTADO ACTUAL (Sin mejoras):

Tipo Incidente	SLE (€)	ARO (%)	ALE (€)
Ransomware	5,650K	15%	847K
Data Breach	3,200K	8%	256K
Phishing	800K	25%	200K
DDoS	1,500K	5%	75K
Insider Threat	2,100K	3%	63K
Availability	400K	20%	80K
TOTAL ALE ANUAL:			1,521K €

POST-REMEDIATION (CMI 3.5+):

Ransomware: 15% → 5%	= 282K
Data Breach: 8% → 2%	= 64K
Phishing: 25% → 10%	= 80K
DDoS: 5% → 1%	= 15K
Insider: 3% → 1%	= 21K
Availability: 20% → 5%	= 20K
TOTAL ALE POST-REMEDIATION:	482K €

ANNUAL BENEFIT: 1,521K - 482K = €1,039K saved per year

SLIDE 10: ROI / ROSI Justificación

Contenido:

RETORNO EN SEGURIDAD (ROSI) - ANÁLISIS DE INVERSIÓN:

Inversión Total:	€730K (2026, fases 1-3)
Beneficio Anual:	€1,039K (ALE reduction)

ROSI Portfolio:	242% en año 1
Payback Period:	8.4 meses (promedio)

DESGLOSE POR INICIATIVA:

Iniciativa	Costo	ROSI	Payback
SIEM	€150K	280%	6.3m
FAIR Quantification	€40K	400%	2.4m
Vulnerability Scanning	€60K	400%	2.4m
TLPT Red Team	€200K	483%	4.1m
Encryption Program	€120K	165%	8.6m
BC/DR Testing	€80K	140%	8.5m
Phishing Simulation	€50K	190%	3.1m
Otros	€30K	175%	4.2m

CONCLUSIÓN:

- ✓ ROI positivo en TODAS iniciativas
- ✓ Payback promedio 5.3 meses
- ✓ Portfolio ROSI 242% año 1 → EXCELENTE
- ✓ RECOMENDACIÓN: Aprobar presupuesto €730K

SLIDE 11: Recomendaciones y Acciones

Contenido:

RECOMENDACIONES PARA JUNTA DIRECTIVA:

1. APROBAR PRESUPUESTO FASE 1: €420K (Q1-Q2 2026)
Iniciativas: SIEM, FAIR, Crisis Comm, Vendors
Justificación: ROSI 280%+ promedio; DORA compliance crítico
Motion: "La Junta autoriza gasto €420K para ciberseguridad crítica"
2. DELEGAR EJECUCIÓN A CISO + PMO
Responsables: CISO (technical), CRO (governance), PMO (delivery)
Reporte: Mensual a CRO; trimestral a Junta
Motion: "Junta asigna responsabilidad CISO+CRO con empoderamiento"
3. ESTABLECER OBJETIVOS CMI
Target Q3 2026: CMI 3.5/5.0 (preparación auditoría)
Target Q4 2026: CMI 3.8/5.0 (excelencia)
Motion: "Junta aprueba targets CMI 3.5 (Q3) y 3.8 (Q4)"
4. SUPERVISORY READINESS
Auditoría probable: Q3 2026 (CNMV/Banco de España)
Preparación: Documentación completa + evidencia gathering
Motion: Implicit en aprobación presupuesto
5. GOVERNANCE FRAMEWORK
Reportes: Trimestral a Junta; mensual a CRO
Escalación: CMI <2.8 = inmediata alerta; >4.0 = celebración
Motion: Implicit en assignment de responsables

SLIDE 12: Cierre y Decisión

Contenido:

RESUMEN EJECUTIVO:

- ✓ CMI Actual: 2.8/5.0 (MANAGED - Developing)
- ✓ Encuesta Exhaustiva: 128 preguntas; 8 módulos; 100% DORA coverage
- ✓ Gaps Identificados: Prioridades claras; remediación planificada
- ✓ Roadmap Definido: 3 fases; 6 meses; €730K presupuesto
- ✓ ROI Justificado: 242% ROSI; 8.4 meses payback; €1M+ ALE reduction
- ✓ Supervisory Readiness: Probable aprobación Q3 2026

DECISIONES REQUERIDAS HOY:

- [] Motion 1: Aprobar €420K Fase 1 presupuesto
- [] Motion 2: Delegar CISO+CR0 con empoderamiento
- [] Motion 3: Establecer targets CMI 3.5/3.8
- [] Motion 4: Aceptar reportes trimestral

PRÓXIMOS PASOS:

- Feb 15: Fase 1 kickoff; SIEM vendor selection
- Feb 28: FAIR training iniciación
- Mar 31: Crisis comm validation completada
- May 31: SIEM operativo; MTTD <15min target
- Jun 30: TLPT execution + Vendor assessments
- Aug 31: Resiliencia testing; CMI target 3.8
- Q3 2026: Supervisory audit (readiness: YES)

¿PREGUNTAS?

[Contacto CISO/CR0 para detalles técnicos]

GUÍA DE DISEÑO

Colores:

- Primario: Azul corporativo (seguridad)
- Acentos: Verde (success/approval) + Rojo (critical gaps)
- Neutro: Gris (background)

Tipografía:

- Títulos: Calibri Bold 28-32pt
- Body: Calibri 12-14pt
- Datos: Calibri 11pt monospace

Elementos Recurrentes:

- Logos institución + DORA (top left/right)
- Footer: "Confidencial | Junta Directiva | Pág X"
- Iconos: Check (✓), Warning (⚠), Critical (⚠⚠), Star (★)

Fin de la Plantilla PowerPoint

Enero 2026 — Presentación Resultados Encuesta DORA